

Third-Party SaaS & OAuth Application Compliance Audit

Statutory GDPR Legal Investigation, Fiduciary Risk Assessment, and Google Workspace App Access Control Audit for Educational Institutions

AUDITED EDUCATIONAL DOMAIN gafe.co.za (Google Workspace for Education)	PRIMARY COMPLIANCE FRAMEWORK EU General Data Protection Regulation (Reg 2016/679) & UK GDPR
SECONDARY JURISDICTIONAL BENCHMARKS POPIA (South Africa Act 4 of 2013) / FERPA & COPPA (USA)	AUDIT WINDOW & BASELINE DATASET September 2026 (180-Day Google Admin SDK Timeline)

2,059 TOTAL APPLICATIONS	2,038 UNCONFIGURED SHADOW IT	27 SUPER ADMIN TOKENS	94 CRITICAL / HIGH RISK
-----------------------------	---------------------------------	--------------------------	----------------------------

 **EXECUTIVE COMPLIANCE SUMMARY**

This statutory investigation evaluated third-party SaaS and OAuth applications connected to the gafe.co.za educational domain. **99.0% of external applications (2,038 apps)** reside in an **UNCONFIGURED** state in Google Admin Console, bypassing mandatory Article 28 Data Processing Agreements (DPAs) and Article 30 Records of Processing Activities (ROPA). Furthermore, **27 active OAuth tokens granted by 7 Super Administrators** create immediate lateral takeover vectors to the institution's entire data store.

1. Legal Framework: Fiduciary & Statutory Responsibilities in Education

1.1 The Fiduciary Duties of Educational Leadership

School Boards, Trustees, Principals, and Executive Leadership hold a direct **Fiduciary Duty of Care and Diligence**. In modern digital education, personal data—specifically that of minor students—is an institutional asset and a legally protected class. Under corporate and charity governance law:

- **Non-Delegable Accountability:** While technical configuration is assigned to IT personnel, ultimate legal liability for data breaches, unlawful processing, and regulatory sanctions rests strictly with the institution's governing body.
- **Child Safeguarding as a Legal Standard:** Educational data contains sensitive behavioral records, academic assessments, communications, and safeguarding notes. Failing to control the egress of minors' data to unvetted commercial vendors constitutes a breach of safeguarding duty.
- **Supply Chain & Vendor Risk Governance:** When an institution permits software integrations, it is legally contracting out the processing of student and staff personal data. Leadership has a duty to perform pre-acquisition due diligence, ongoing monitoring, and incident response.

1.2 Global Regulatory Landscape: The Broad Spectrum

JURISDICTION / LAW	LEGAL CLASSIFICATION	CORE MANDATE FOR THIRD-PARTY APPS	STATUTORY NON-COMPLIANCE RISK
EU GDPR / UK GDPR (Regulation 2016/679)	School is Data Controller ; Vendor is Data Processor .	Mandatory Article 28 DPA, Article 30 ROPA, Article 35 DPIA for high-risk tools, strict data minimisation (Art. 5).	Administrative fines up to €20M / 4% global turnover; binding processing bans.
POPIA (South Africa) (Act 4 of 2013)	School is Responsible Party ; Vendor is Operator .	Condition 7 security safeguards; Section 34 general prohibition on processing children's personal data without authorization.	Administrative fines up to ZAR 10M, civil lawsuits, public enforcement notices.
FERPA & COPPA (United States)	Direct Institutional Control / In Loco Parentis.	FERPA "School Official" exemption requires vendor to be under direct school control. COPPA forbids non-educational tracking under 13.	Loss of federal educational funding; FTC civil monetary enforcement.

1.3 Regulatory Enforcement Precedents: The European Experience

The risks of unvetted cloud software in education are demonstrated by landmark European Data Protection Authority decisions:

- **The Danish Datatilsynet Landmark Ruling (Helsingør Municipality):** In 2022–2024, the Danish DPA issued an injunction banning municipal schools from utilizing Google Workspace and Chromebooks due to lack of control over third-party sub-processors, secondary telemetry use, and unlawful US data transfers. The DPA explicitly reprimanded the municipality for failing to act as an accountable Data Controller.
- **Dutch SIVON & SURF Sectoral DPIA:** Dutch educational authorities negotiated mandatory contractual and technical mitigations with Google, requiring strict purpose limitation, elimination of advertising/profiling on student accounts, and granular administrative controls over third-party extensions.

2. GDPR Narrow Scope: Specific Mandates for Third-Party OAuth Apps

Under GDPR (and UK GDPR), third-party OAuth applications in Google Workspace trigger specific statutory requirements:

GDPR ARTICLE	STATUTORY REQUIREMENT	THIRD-PARTY OAUTH APP APPLICATION	COMPLIANCE STATUS IN GAFE.CO.ZA
Art. 5(1)(c)	Data Minimisation	Apps must only request scopes strictly necessary for educational function. Full-Drive/full-Gmail scopes violate this rule.	NON-COMPLIANT 5 apps hold full Drive access; multiple hold full Gmail.
Art. 5(1)(e)	Storage Limitation	Access tokens and historical app permissions must not persist indefinitely when no longer in active use.	NON-COMPLIANT 16 dormant "Trusted" apps retained without active users.
Art. 5(1)(f) & 32	Security of Processing (TOMs)	Implementation of technical access controls to prevent unauthorized access or privilege escalation.	NON-COMPLIANT 27 tokens on Super Admin accounts create lateral takeover paths.
Art. 8 & Rec. 38	Children's Data Protection	Prohibits behavioral tracking, automated profiling, and commercial harvesting of minor students.	AT RISK Unconfigured apps enable ad-supported tools to track students.
Art. 24 & 25	Privacy by Design & Default	Default institutional configuration must prevent unauthorized third-party data egress.	NON-COMPLIANT 2,038 unconfigured apps demonstrate open-by-default posture.
Art. 28	Processor Agreements (DPA)	Mandatory binding legal contract detailing data types, duration, security, and audit rights.	MAJOR BREACH Vast majority of 2,038 shadow apps lack institutional DPAs.
Art. 30	Records of Processing (ROPA)	Exhaustive, maintained register of all external data processors, data categories, and recipients.	NON-COMPLIANT Shadow IT apps absent from institutional ROPA register.
Art. 44–49	International Data Transfers	Verification of EU-US Data Privacy Framework (DPF) certification or Standard Contractual Clauses (SCCs).	UNVERIFIED Numerous US SaaS vendors unvetted for transfer legality.

2.1 The Seven Mandatory Audits Educational Institutions Must Conduct

- Application Discovery & Census Audit:** Complete inventory reconciliation between Google Admin Reports API audit events and live Directory API tokens (``users.tokens.list``).
- Scope Threat & Privilege Audit:** Categorization of requested OAuth scopes on a 1–5 threat scale, identifying restricted scopes (e.g. ``mail.google.com``, ``drive``, ``contacts``).
- Administrative Blast Radius Audit:** Identification of high-privilege Super Admin accounts holding third-party OAuth grants.
- App Access Control Baseline Audit:** Verification that Google Admin Console App Access Control is locked down rather than left unconfigured.
- Token Lifecycle & Dormancy Audit:** Identification and automated revocation of stale/orphan tokens (inactivity > 90 days).
- Vendor Due Diligence & Breach Audit:** Verification of publisher verification status, active DPA contracts, and historical security incidents.
- Cross-Border Transfer Audit:** Verification of vendor data hosting residency and international transfer mechanisms (SCCs/DPF).

3. Technical Audit Findings: Tenant Inventory (`gafe.co.za`)

3.1 Top Critical & High-Risk Unconfigured Applications

The following applications possess critical permissions but reside in an **UNCONFIGURED** state in Google Admin Console—meaning any student or staff member can authorize them without central IT review:

APPLICATION NAME	VENDOR / PUBLISHER	RISK SCORE	POLICY STATUS	PRIMARY THREAT VECTOR
Yet Another Mail Merge (YAMM)	YAMM / Anvil SAS	5.00 CRITICAL	UNCONFIGURED	Full Gmail send/read/draft impersonation.
Mergo	Mergo Inc.	5.00 CRITICAL	UNCONFIGURED	Mass mailing & mailbox access.
Chromebook Getter	CDW / Amplified IT	4.36 CRITICAL	UNCONFIGURED	Chrome OS device & directory management.
autoCrat	New Visions CloudLab	4.62 CRITICAL	UNCONFIGURED	Full Google Drive read/write & sheet access.
Signeasy	Signeasy Inc.	4.72 CRITICAL	UNCONFIGURED	Document extraction & digital signature store.
n8n.cloud	n8n GmbH	4.59 CRITICAL	UNCONFIGURED	Automated workflow execution & data exfiltration.
Mailtrack / Mail Merge	Mailtrack Inc.	4.56 CRITICAL	UNCONFIGURED	Tracking beacons & mailbox scanning.
Lusha (Web Application)	Lusha Systems Inc.	3.23 HIGH	UNCONFIGURED	Contact & directory scraping.

3.2 Super Administrator Token Exposure Ledger

 **CATASTROPHIC BLAST RADIUS: SUPER ADMIN TOKENS DETECTED**

7 Super Administrators hold 27 active third-party OAuth grants. Under GDPR Art. 32, failing to ring-fence administrative accounts from third-party application consent represents gross organizational negligence.

SUPER ADMIN ACCOUNT	ACTIVE TOKENS	KEY APPLICATIONS AUTHORIZED	REMEDIACTION ACTION
alister@gafe.co.za	9 tokens	Chromebook Getter, GAM Creation, Gemini Studio, Apple Business Mgr	IMMEDIATE REVOCATION
deidre@gafe.co.za	5 tokens	Chromebook Getter, Unverified Scripts, Core Admin Tools	IMMEDIATE REVOCATION
karien@gafe.co.za	4 tokens	Chromebook Getter, Wayground (Quizizz), Internal Scripts	IMMEDIATE REVOCATION
kevin@gafe.co.za	4 tokens	Gemini Studio, Google Chat Studio, Unverified Tools	IMMEDIATE REVOCATION
farrakhan@gafe.co.za	3 tokens	GAM Project Creation, Third-Party Administrative Tools	IMMEDIATE REVOCATION
pavel@gafe.co.za	1 token	Third-Party Extension Client	IMMEDIATE REVOCATION
themba@gafe.co.za	1 token	Third-Party Extension Client	IMMEDIATE REVOCATION

4. Compliance Vulnerabilities: Dormant Tokens & Supply Chain

4.1 Dormant "Trusted" Applications (Policy Backdoors)

An application marked as TRUSTED in Google Admin Console bypasses all scope restrictions. When an app is abandoned or unused, leaving it marked as TRUSTED grants a permanent, dormant backdoor to the vendor's cloud environment:

APPLICATION NAME	VENDOR	ACTIVE USERS	CONSOLE STATUS	RECOMMENDED ACTION
Mailsuite	Mailtrack / Mailsuite, S.L.	0 Users	TRUSTED	DOWNGRADE TO BLOCKED
OrbitNote (Web Application)	Texthelp Ltd.	0 Users (6 Entries)	TRUSTED	DOWNGRADE TO LIMITED
Canva (Android / Web)	Canva Pty Ltd	0 Users	TRUSTED	DOWNGRADE TO LIMITED
Zoho CalSync (Android)	Zoho Corporation	0 Users	TRUSTED	DOWNGRADE TO BLOCKED
Quizizz (Android Client)	Quizizz Inc.	0 Users	TRUSTED	DOWNGRADE TO LIMITED
MyLogin (Web Application)	Wonde Ltd (MyLogin)	1 User	TRUSTED	RETAIN WITH AUDIT

4.2 Vendor Breach History & Supply Chain Threat Tracking

Under GDPR Article 28, the Data Controller must continuously verify the technical security of vendors. AdminLens actively ring-fences vendors with public breach histories:

VENDOR / TOOL	INCIDENT DATE	BREACH DETAILS & SCOPE OF IMPACT	GOVERNANCE REQUIREMENT
Canva Pty Ltd (Canva Charts / Web)	2019-05-24	139M user accounts exposed; customer credentials, salt/hashed passwords exfiltrated.	Mandatory verification of SSO passwordless enforcement & DPA addendum.
Bitly, Inc. (Bitly URL Shortener)	2014-05-08	Account credential compromise; unauthorized adversary access to OAuth tokens.	Token rotation verification; restrict to non-administrative organizational units.

 **SUPPLY CHAIN MONITORING POLICY MANDATE**

Vendors with historical security incidents must undergo annual technical posture re-evaluations. Ensure that third-party tokens are segmented from Super Admin accounts and strictly prohibited from accessing restricted Google Workspace scopes.

5. Actionable Remediation Plan & Institutional Sign-Off

5.1 Playbook 1: Immediate Super Admin Token Revocation (GAM CLI)

Execute the following automated Google Apps Manager (GAM) batch script to immediately revoke all 27 Super Admin tokens:

```
#!/bin/bash
# --- 1. Revoke Tokens for alister@gafe.co.za (9 Tokens) ---
gam user alister@gafe.co.za delete token clientid 871655740233-ia5enbpe9r7o18h2ajle4vdd51vhflp.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 696916210722-n0mvdqjq01ebg21eeaaaggm9vb0jbr6.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 297408095146-fug707qsjv4ikron0hugpevbrjhkmsk7.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 458969862783-lsmfdj4v8qbnibgarkala99400lhsa13.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 72867247940-n969jo6c29qg22m8sodb2hftn6dck1mk.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 521549528509-f17hlgjd91nbi5sooc73ia3d4dqln10s.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 296758037454-ssrceub8i8moppipckhk61mk8go2kk6t.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 823511539352-ojaretejkl9s5sdvkic0te923pt7knpu.apps.googleusercontent.com
gam user alister@gafe.co.za delete token clientid 821073268825-uj405qcuu2pbpq5ab05rsupc98ldq2ou.apps.googleusercontent.com

# --- 2. Revoke Tokens for deidre, karien, kevin, farrakhan, pavel, themba (18 Tokens) ---
gam user deidre@gafe.co.za delete token clientid 946018238758-bi6ni53dfoddln97pk3b8i7nphige40.apps.googleusercontent.com
gam user deidre@gafe.co.za delete token clientid 871655740233-ia5enbpe9r7o18h2ajle4vdd51vhflp.apps.googleusercontent.com
gam user deidre@gafe.co.za delete token clientid 953348912797-h2fo9tmk42mnrkk0kc6gula9i8ipv3re.apps.googleusercontent.com
gam user deidre@gafe.co.za delete token clientid 718809722883-l2mt5r2m2omka59ahjmljs78slbubsd7.apps.googleusercontent.com
gam user deidre@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
gam user karien@gafe.co.za delete token clientid 871655740233-ia5enbpe9r7o18h2ajle4vdd51vhflp.apps.googleusercontent.com
gam user karien@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
gam user karien@gafe.co.za delete token clientid 968320677628-ort3v6hao1mu08dli4eg97it7rgo7e43.apps.googleusercontent.com
gam user karien@gafe.co.za delete token clientid 58172892053-faol054co4k3tsmtbtuk41v4si41slq0.apps.googleusercontent.com
gam user kevin@gafe.co.za delete token clientid 296758037454-ssrceub8i8moppipckhk61mk8go2kk6t.apps.googleusercontent.com
gam user kevin@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
gam user kevin@gafe.co.za delete token clientid 469390422673-r0p2tar3lgjlnhtsv4t4uonq4bi2svf8.apps.googleusercontent.com
gam user kevin@gafe.co.za delete token clientid 873507009103-gi4ff8nkju6ggaurt6ebbiqrfrmr0c79j.apps.googleusercontent.com
gam user farrakhan@gafe.co.za delete token clientid 297408095146-fug707qsjv4ikron0hugpevbrjhkmsk7.apps.googleusercontent.com
gam user farrakhan@gafe.co.za delete token clientid 585538275436-4lk6emnr2l22atsdk6lfst4d4nhkgbku.apps.googleusercontent.com
gam user farrakhan@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
gam user pavel@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
gam user themba@gafe.co.za delete token clientid 936475272427.apps.googleusercontent.com
echo "✓ Remediated: All 27 high-privilege Super Admin tokens revoked."
```

5.2 Playbook 2: Google Admin Console Global Policy Lockdown

1. Navigate to **Security > Access and data control > API controls > App access control**.
2. Under **Settings**, set Unconfigured third-party apps to **"Block all third-party apps unless explicitly approved"**.
3. Under **App Access Control**, downgrade the 16 dormant applications from TRUSTED to LIMITED or BLOCKED.
4. Under **Organizational Units (OUs)**, restrict sensitive app permissions exclusively to Staff OUs; block third-party API consent for Student OUs.

5.3 Institutional Sign-Off & Verification Block

Data Protection Officer (DPO)
Attestation of Statutory Compliance

Date: _____

Head of School / Principal
Executive Duty of Care Sign-Off

Date: _____

Chair of the Board of Governors
Fiduciary Governance Acceptance

Date: _____